عرض تقديمي للضيوف

مرقاب

منصة عمليات أمنية مدعومة بالذكاء الاصطناعي للمنشآت الصغيرة والمتوسطة

Alaa Rafa Al Saad
Nouf Saleh Altalhi
Bdoor Fahed Alosaimi

برج مراقبة لكل منشأة صغيرة

يمنح مرقاب المنشآت الصغيرة والمتوسطة سير العمل الأساسي لمركز العمليات الأمنية (SOC) دون الحاجة إلى فريق بحجم مركز كامل.

١

ترى

تحويل الأحداث الأمنية الخام إلى حوادث مفهومة مع الأدلة وسياق MITRE ATT&CK.

٢

تقرّر

كل حادثة عالية أو حرجة تحصل على مؤقّت استجابة مدته 5 دقائق وتحقيق موجَّه.

٣

تتصرّف

عزل الجهاز لا يتم إلا بإجراء مُصرَّح به، ومؤكَّد من الوكيل، ومُسجَّل في سجل التدقيق.

الهجمات نفسها التي تواجه الشركات الكبرى... بمدافعين أقل بكثير

ما تواجهه المنشآت الصغيرة

- التصيّد الاحتيالي والمرفقات الضارة
- هجمات تخمين كلمات المرور
- برامج الفدية وتشفير البيانات
- اتصالات القيادة والتحكم (C2)

ما ينقصها

- السياق: الأدوات تُصدر تنبيهات خامًا لا حوادث
- المسؤولية: لا أحد مُكلَّف بمتابعة التنبيه الحرج في الوقت المناسب
- الأتمتة الآمنة: «حظر كل شيء» قد يعطّل العمل
- الخصوصية: لا يمكن إرسال السجلات الداخلية إلى ذكاء اصطناعي خارجي

لماذا تحتاج المنشآت الصغيرة إلى قدرات مركز العمليات الأمنية؟

الاكتشاف وحده ليس أمنًا

مركز العمليات الأمنية هو الحلقة التي تربط التنبيه بالقرار ثم بالإجراء. غالبًا ما تملك المنشآت الصغيرة أدوات تكتشف، لكن دون هذه الحلقة.

الفرز

أيّ تنبيهات اليوم تستحق الاهتمام فعلًا؟

التحقيق

ماذا حدث؟ وأين؟ وهل رأيناه من قبل؟

الاستجابة

من يتصرّف؟ وبأي سرعة؟ وبأي صلاحية؟

الإثبات

ما الذي تم؟ وهل يمكن إثباته لاحقًا؟

ثلاثة تطبيقات وخادم خلفي واحد

لوحة مركز العمليات الأمنية

تطبيق ويب (React) للمدير ومحلل الأمن وفني تقنية المعلومات: نظرة عامة، الحوادث، خريطة الشبكة الحية، التذاكر، السياسات، التقارير، سجلات التدقيق، إدارة المستخدمين. تم التحقق

الخادم الخلفي (API)

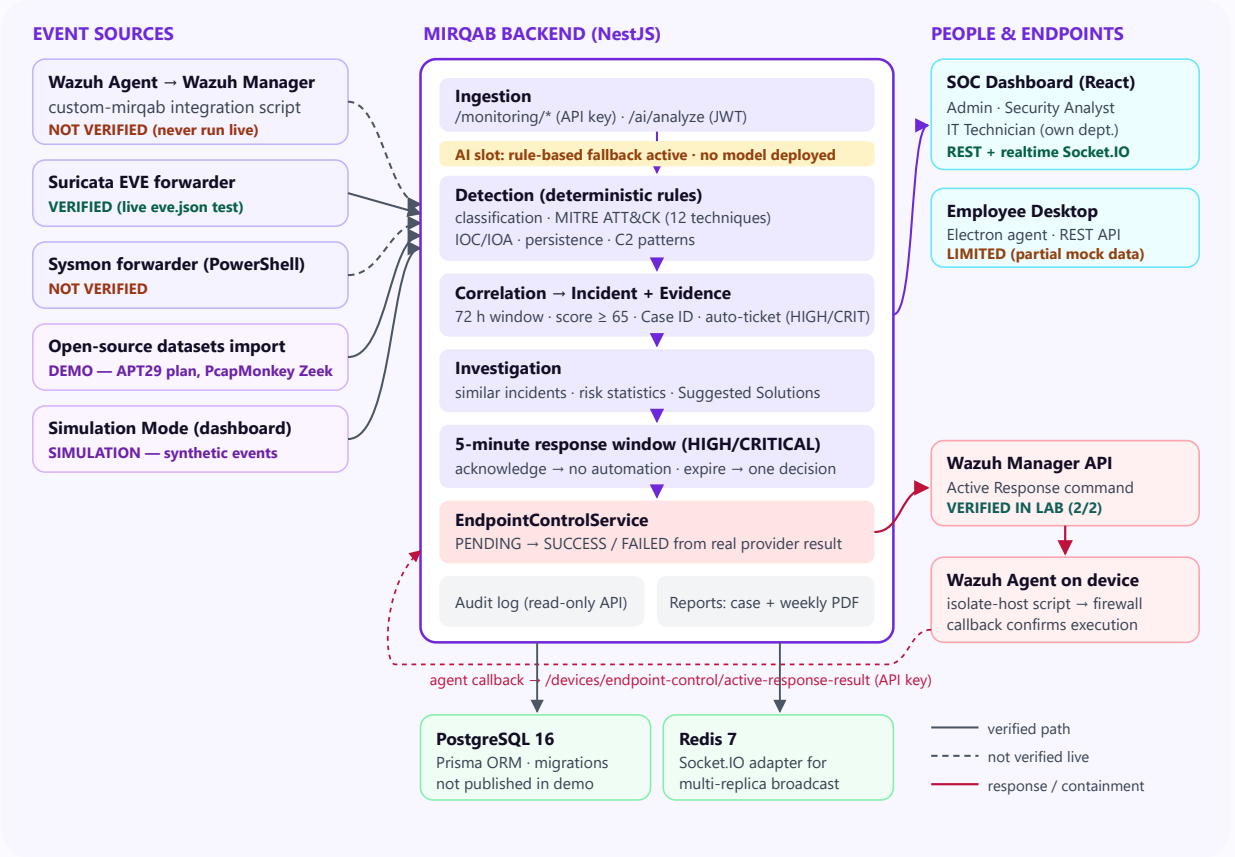
NestJS + PostgreSQL + Prisma + Redis + Socket.IO: الاستقبال، الاكتشاف، الربط، نافذة الاستجابة، التحكم بالأجهزة، التقارير. تم التحقق 421 اختبارًا ناجحًا

تطبيق الموظف المكتبي

وكيل (Electron): صحة الجهاز، درجة الأمان، معلومات الجهاز، الإصلاحات المقترحة. محدود بعض الشاشات تستخدم بيانات تجريبية موسومة بوضوح

الحالة في 27 سبتمبر 2026: نموذج أولي عامل يعمل محليًا عبر Docker، غير منشور في بيئة إنتاج.

مسار البيانات الفعلي



الخط المتقطّع: مُنفَّذ لكن لم يُتحقق منه تشغيليًا. مرقاب لا يقرأ من Wazuh Indexer. (المخطط باللغة الإنجليزية)

من الحدث إلى قرار مدعوم بالأدلة

١ **الاستقبال**
من مُرسِلات Wazuh وSuricata وSysmon، إضافة إلى بيانات عامة ووضع المحاكاة للعروض.

٢ **الاكتشاف**
تحديد الخطورة بالقواعد، وتقنية MITRE، ومؤشرات الاختراق والهجوم، وأنماط الاستمرارية والقيادة والتحكم.

٣ **الربط**
دمج الأحداث المرتبطة في قضية واحدة (خلال 72 ساعة وبدرجة تشابه 65 فأكثر) برقم قضية.

٤ **التنبيه**
للحوادث العالية والحرجة: تذكرة تلقائية، وإشعار، ونافذة استجابة مدتها 5 دقائق.

٥ **التحقيق والاستجابة**
الأدلة، والحوادث المشابهة، والحلول المقترحة، وإجراءات مؤكَّدة.

٦ **التوثيق**
الخط الزمني، وسجل التدقيق، وتقرير القضية، والتقرير الأسبوعي.

اكتشاف حتمي قابل للتفسير

ما يُنفَّذ على كل حدث

- **التصنيف**: الخطورة بحسب القواعد
- **MITRE ATT&CK**: 12 تقنية منتقاة
- **مؤشرات الاختراق (IOC)**: عناوين IP، البصمات، النطاقات، الروابط، البريد الإلكتروني
- **مؤشرات الهجوم (IOA)**: سرقة بيانات الاعتماد، الانتشار الجانبي، حقن العمليات، التعتيم، التهرّب من الدفاعات
- **الربط** بقضية مفتوحة قائمة أو إنشاء قضية جديدة

صادق بالتصميم

لا تطابق يعني لا مؤشر، والأحداث غير المطابقة تبقى **غير مصنّفة (UNCLASSIFIED)** بدلًا من التخمين.

في العرض التجريبي بقيت 11 من أصل 27 حادثة أُنشئت من البيانات العامة غير مصنّفة، وتذكر ملاحظات البيانات أن أحداث الشبكة الستة تُصنَّف «غير مصنّفة / منخفضة».

تم التحقق | تغطية محدودة

سير عمل الاستجابة خلال 5 دقائق

كل حادثة حرجة لها مؤقّت

T0

الاكتشاف

إنشاء حادثة عالية أو حرجة. الموعد النهائي = T0 + 5 دقائق.

T0

الإشعار

إشعار «الاستجابة مطلوبة» لمستخدمي المركز المخوَّلين برؤيتها.

أقل من 5 د

الإقرار

يقرّ المحلل بالحادثة، فلا يحدث عزل تلقائي أبدًا.

5 د

انتهاء المهلة

قرار واحد لا يتكرر، يُتخذ تحت قفل في قاعدة البيانات.

بعد ذلك

التوثيق

تسجيل النتيجة والإشعار وقيد التدقيق، وتُسجَّل الاستجابات المتأخرة.

الحوادث المتوسطة والمنخفضة لا تؤدي أبدًا إلى عزل تلقائي، بل تنتظر المحلل دائمًا. المنطق تم التحقق باختبارات الوحدة.

من يُبلَّغ... ومن لا يُبلَّغ

المُنفَّذ

- إشعارات فورية داخل التطبيق عبر Socket.IO
- «الاستجابة مطلوبة» للحوادث العالية والحرجة الجديدة
- «نتيجة الاحتواء» عند انتهاء المهلة
- المستلمون هم تحديدًا مستخدمو المركز المخوَّلون برؤية الحادثة: المدير، ومحلل الأمن، وفني تقنية المعلومات في القسم نفسه

تم التحقق

لم يُنفَّذ بعد: الموظف

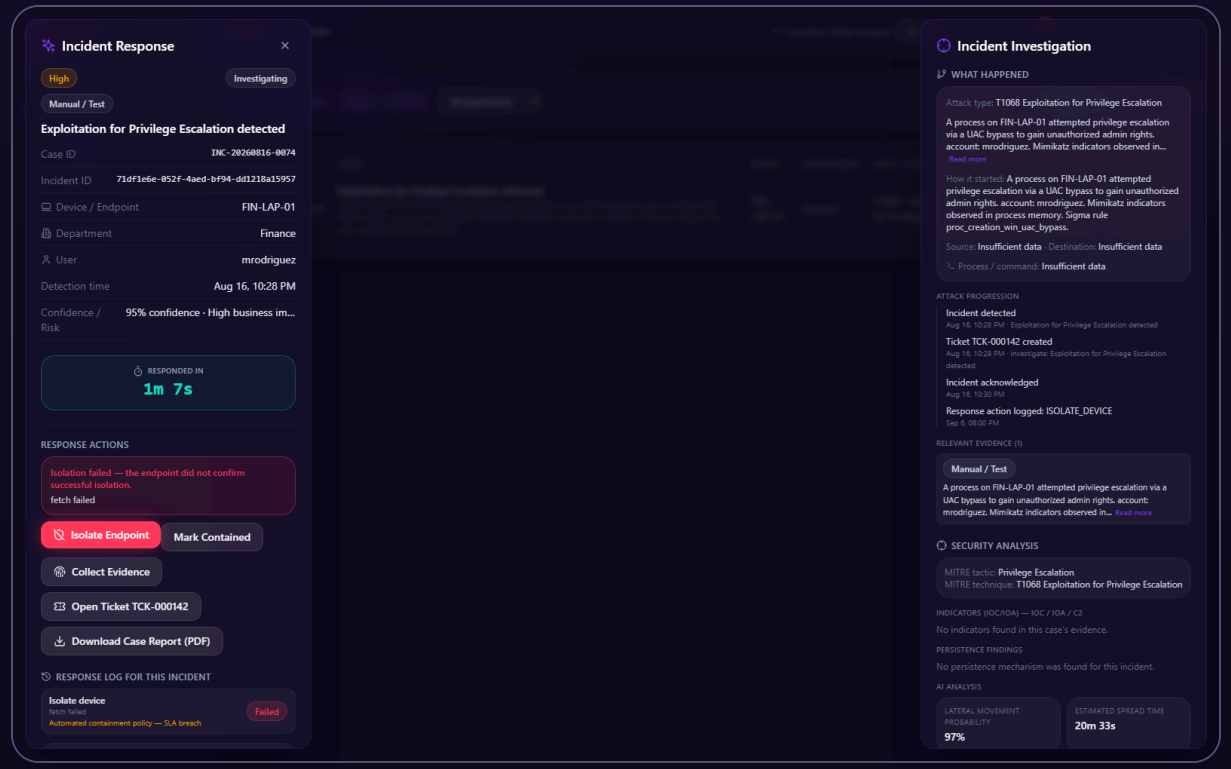
لا يوجد في الخادم الخلفي نموذج لربط الحوادث بموظف بعينه، لذلك **لا** يُبلَّغ الموظف المتأثر بشكل فردي.

يعرض تطبيق الموظف المكتبي صحة الجهاز والإصلاحات المقترحة، وبعض شاشاته تستخدم بيانات تجريبية موسومة بوضوح.

محدود

«إقرار وبدء التحقيق»

- يسجّل من استجاب ومتى
- لا يتكرر: النقرة الثانية لا تُنشئ سجلًا مكررًا
- قبل الموعد النهائي: يُلغى العزل التلقائي نهائيًا
- بعد الموعد النهائي: يُسجَّل كاستجابة متأخرة ولا يُلغي عزلًا تم بصمت
- أي تغيير في حالة الحادثة يُحتسب استجابة أيضًا



لقطة حقيقية (22 سبتمبر 2026): «تمت الاستجابة خلال 1 د 7 ث»، حادثة اختبار في بيئة التطوير.

لا أتمتة إلا عند تحقق جميع الشروط

لا يُطلب العزل إلا إذا...

- كانت الخطورة عالية أو حرجة
- لم يستجب أحد خلال 5 دقائق
- كانت الحادثة **غير** ناتجة عن المحاكاة
- كانت سياسة «نافذة الاستجابة 5 دقائق» مفعّلة
- كان هناك مزوّد مُهيّأ للتحكم بالأجهزة

...ثم

- يُحفظ الإجراء أولًا بحالة «قيد الانتظار»
- يُستدعى المزوّد الحقيقي
- يتحوّل السجل نفسه إلى «نجاح» أو «فشل» بحسب النتيجة الفعلية
- لا يُستشار الذكاء الاصطناعي، فالقرار قائم على القواعد

في بيئة التطوير سُجّلت المحاولات **فاشلة** لعدم وجود جهاز حقيقي يمكن الوصول إليه. لم يُثبت بعد عزل تلقائي ناجح على وكيل حي.

محدود

احتواء يمكن إثباته

١ **التفويض**
التحقق من الدور والقسم، وتحديد الجهاز في الخادم من الحادثة نفسها.

٢ **التأكيد**
يؤكد المحلل أن «هذا الجهاز وحده سيتأثر».

٣ **الإرسال**
مرقاب ← واجهة Wazuh Manager ← الاستجابة النشطة.

٤ **التحقق**
يطبّق سكربت الوكيل عزل الجدار الناري ويُرسل تأكيدًا، وعندها فقط تُسجَّل «نجاح».

الدليل

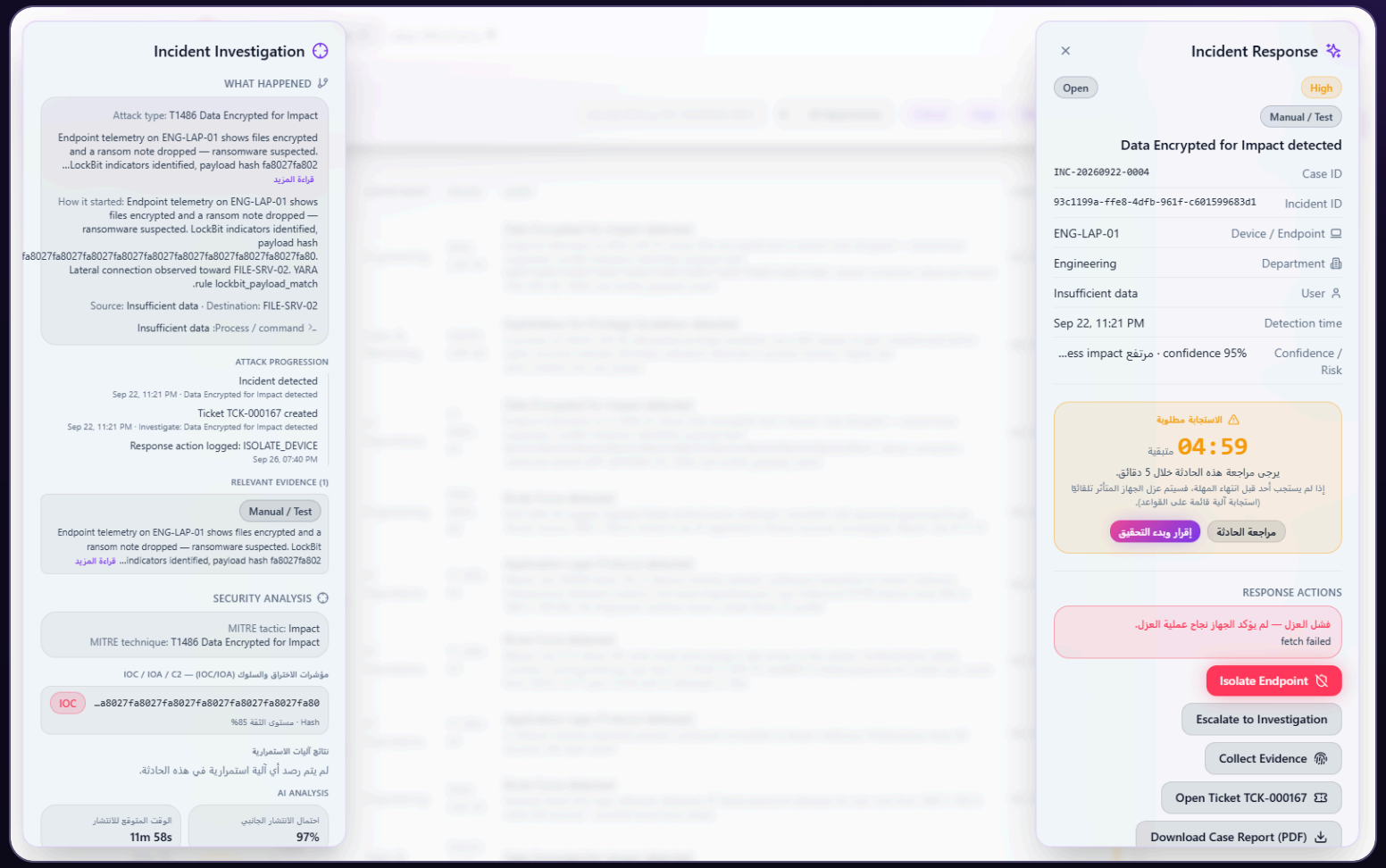
تم التحقق في المختبر عمليتا عزل ناجحتان من أصل 2 عبر مرقاب على وكيل اختبار آمن (Linux) داخل حاوية، خلال 11–15 ثانية.

لم يتم التحقق سكربت Windows والأجهزة الفعلية

غير مُنفَّذ رفع العزل من داخل مرقاب

متوقف (عائق خارجي) الإصدار العام Wazuh 4.14.7، إذ استخدم المختبر إصدارًا مرشحًا

نافذتان: استجابة وفهم



لقطة حقيقية (26 سبتمبر 2026) بالواجهة العربية والسمة الفاتحة، حادثة اختبار في بيئة التطوير. بعض التسميات ما زالت بالإنجليزية محدود.

12 تقنية منتقاة تُطابَق بشكل حتمي

ID	Technique	Tactic
T1566	Phishing	Initial Access
T1110	Brute Force	Credential Access
T1204	User Execution	Execution
T1059	Command & Scripting Interpreter	Execution
T1046	Network Service Discovery	Discovery
T1068	Exploitation for Priv. Escalation	Privilege Escalation
T1053	Scheduled Task/Job	Persistence
T1078	Valid Accounts	Persistence
T1071	Application Layer Protocol	Command and Control
T1105	Ingress Tool Transfer	Command and Control
T1567	Exfiltration Over Web Service	Exfiltration
T1486	Data Encrypted for Impact	Impact

لماذا قائمة منتقاة؟

يجب أن تكون كل مطابقة قابلة للتفسير والاختبار. وإذا فُعّل مزوّد ذكاء اصطناعي مستقبلًا، فستُتحقق مخرجاته من هذا المرجع لرفض أي معرّف تقنية مُختلَق.

الأحداث غير المطابقة تبقى **غير مصنّفة**.

تم التحقق محدود

مؤشرات تُستخرج... ولا تُختلق

مؤشرات الاختراق (IOC)

عناوين IP، وبصمات الملفات، والنطاقات، والروابط، وعناوين البريد الإلكتروني، ولكلٍّ منها مستوى ثقة.

مؤشرات الهجوم (IOA)

أنماط سلوكية: سرقة بيانات الاعتماد، والانتشار الجانبي، وحقن العمليات، والتنفيذ المُعتَّم، والتهرّب من الدفاعات.

الأدلة

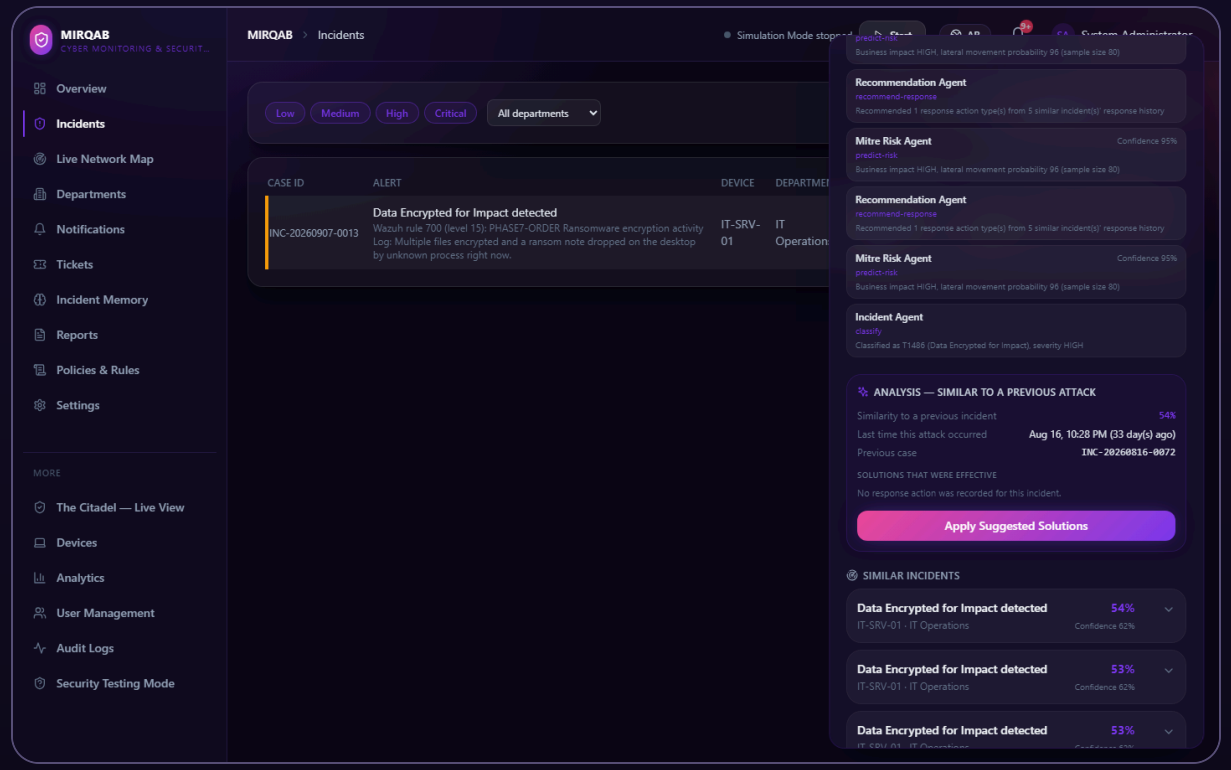
يُحفظ كل حدث مساهم مع نصه الخام، ووسم مصدره (وكيل حي، بيانات مفتوحة، محاكاة، يدوي/اختبار)، ودرجة ارتباطه.

تُكتشف أيضًا آليات الاستمرارية (المهام المجدولة، الخدمات، مفاتيح التشغيل...) وأنماط القيادة والتحكم، وتُربط بـ MITRE. تم التحقق

التعلّم مما نجح سابقًا

- العثور على الحوادث السابقة المشابهة بتشابه المتجهات، ضمن نطاق القسم
- إصلاحات من دليل خاص بكل تقنية، إضافة إلى الإجراءات التي نجحت في قضايا مشابهة
- زر «تطبيق الحلول المقترحة» يُنشئ الإجراءات، والإجراءات عالية الأثر تتطلب موافقة المحلل
- «الوكلاء» الظاهرون في اللوحة أغلفة مسمّاة لخدمات حتمية، ولا يستطيع أيٌّ منهم تنفيذ استجابة

تم التحقق



لقطة حقيقية (19 سبتمبر 2026): تشابه 54% مع قضية سابقة قبل 33 يومًا.

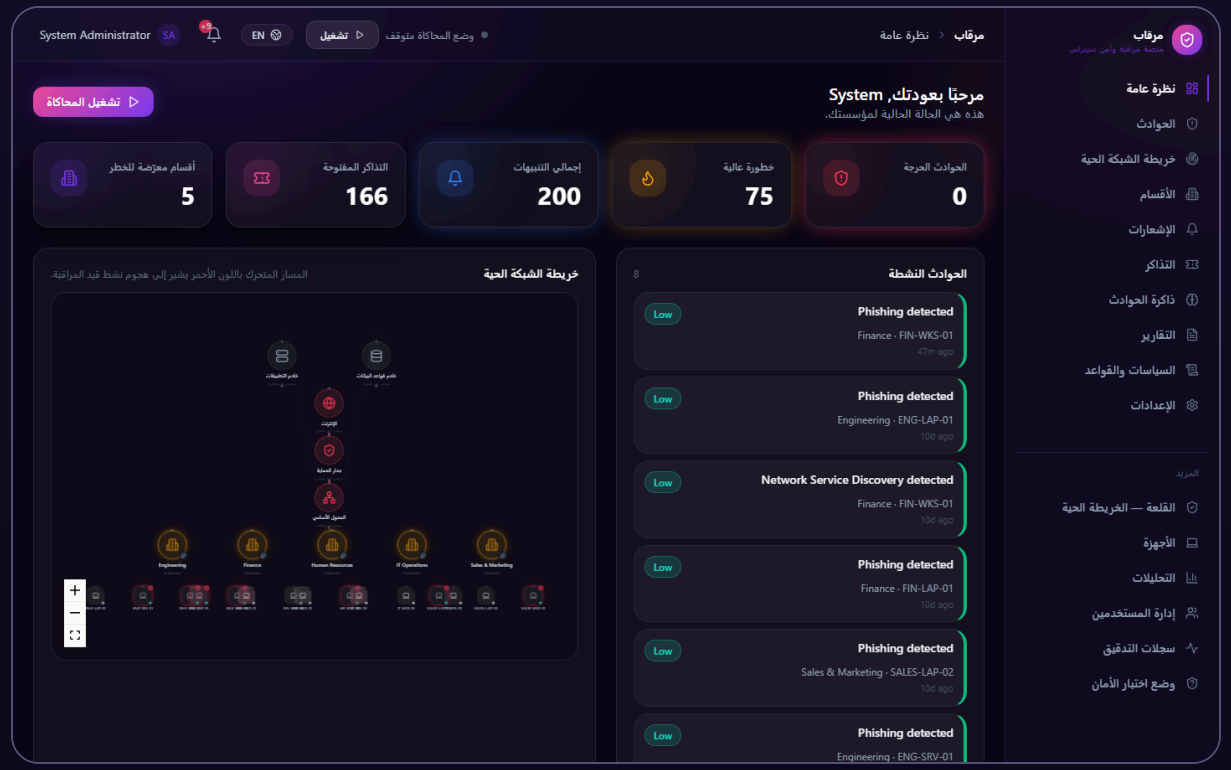
المنشأة كخريطة حيّة

- الإنترنت ← الجدار الناري ← المحوّل الأساسي ← الخوادم ← الأقسام ← الأجهزة
- إبراز الهجمات النشطة، والنقر على الجهاز يفتح حادثته
- شاشة «القلعة — العرض الحي»
- عرض مسار الهجوم لخطة محاكاة APT29 العامة

عرض/محاكاة

- مبنية من سجلات الأجهزة والحوادث في مرقاب، وليست ماسحًا للشبكة

تم التحقق



لقطة حقيقية (20 سبتمبر 2026) بالواجهة العربية، والأرقام من بيانات بيئة التطوير.

إثبات عند الطلب وكل أسبوع

١

تقرير القضية (PDF)

11 قسمًا لكل حادثة: الملخص، الأدلة، الخط الزمني، مؤشرات الاختراق، مؤشرات الهجوم، الاستمرارية، القيادة والتحكم، تحليل الذكاء الاصطناعي، إجراءات الاستجابة، التوصيات، سجل التدقيق. الوصول إليه مقيّد بصلاحيات الحادثة نفسها.

تم التحقق

٧

التقرير الأسبوعي لمركز العمليات (PDF)

يُولَّد كل يوم اثنين الساعة 05:00 بتوقيت UTC للأسبوع المنتهي، لكل منشأة على حدة، أو عند الطلب من صفحة التقارير.

تم التحقق

مؤمَّن ومُختبَر عبر 18 مرحلة

الهوية

- رموز JWT مثبّتة على HS256
- تدوير رموز التحديث مع كشف إعادة الاستخدام
- تشفير bcrypt، وتحديد معدل تسجيل الدخول (5 محاولات في الدقيقة)

الوصول

- 4 أدوار مع تقييد بحسب القسم
- عزل المنشآت عن بعضها
- حراسة على مستوى الكائن (IDOR/BOLA)

المنصة

- تحقق صارم من المدخلات
- اتصال Socket.IO موثَّق ومقيَّد بالغرف
- سجل تدقيق للقراءة فقط، وTLS، وحاوية دون صلاحيات الجذر

38 مجموعة اختبارات تضم 421 اختبارًا للخادم الخلفي، جميعها ناجحة في 27 سبتمبر 2026. المرحلة 4 (إصدار Wazuh) متوقفة والمرحلة 8 (الذكاء الاصطناعي المستضاف ذاتيًا) لم يتم التحقق.

مسار العرض

ما الذي سنعرضه

١ تسجيل الدخول

٢ لوحة المعلومات

٣ الحادثة

٤ التحقيق

٥ الأدلة

٦ MITRE

٧ الحلول المقترحة

٨ مؤقّت الاستجابة

٩ خريطة الشبكة

١٠ سير عمل العزل

١١ الإشعارات

١٢ التقارير

بيانات العرض: خطة APT29 العامة من OTRF Security-Datasets وأحداث PcapMonkey Zeek. لا يستطيع العرض التجريبي عزل أجهزة حقيقية ولا يستخدم ذكاءً اصطناعيًا خارجيًا. عرض/محاكاة

ما نصرّح به بصدق

- غير منشور يعمل محليًا عبر Docker بشهادة TLS ذاتية التوقيع
- لم يتم التحقق الذكاء الاصطناعي المستضاف ذاتيًا: لم يُنشر أي نموذج، وكل التحليل قائم على القواعد
- مختبر فقط ثبت العزل على وكيل داخل حاوية، لا على أجهزة فعلية
- محدود لم يُثبت بعد نجاح الاحتواء التلقائي على جهاز حي
- متوقف صورة Wazuh 4.14.7 العامة لم تكن متاحة عند الفحص
- لم يتم التحقق سكربت التحويل من Wazuh Manager، ومُرسِل Sysmon
- محدود 12 تقنية MITRE، وترجمة عربية جزئية، وإشعارات لمستخدمي المركز فقط
- لم يتم التحقق اختبار الأحمال، وتشغيل العرض على جهاز نظيف مستقل

الخطوات القادمة مخطط

ذكاء اصطناعي خاص

نشر نموذج مستضاف ذاتيًا وتقييمه على عتاد مناسب داخل شبكة العميل.

أجهزة حقيقية

التحقق من العزل على أجهزة Windows وLinux فعلية، وإضافة «رفع العزل».

الإنتاج

نطاق حقيقي وشهادة TLS من جهة موثوقة، ونسخ احتياطي آلي، وإجراءات تعافٍ من الكوارث، واختبار أحمال.

Wazuh

الانتقال إلى إصدار عام، وتشغيل التكامل مع المدير من البداية إلى النهاية.

التغطية

المزيد من تقنيات MITRE وقواعد الاكتشاف.

الأشخاص

ترجمة عربية كاملة، وإشعارات على مستوى الموظف.

الفريق

شكرًا لكم

مرقاب — منصة عمليات أمنية مدعومة بالذكاء الاصطناعي للمنشآت الصغيرة والمتوسطة

Alaa Rafa Al Saad

Nouf Saleh Altalhi

Bdoor Fahed Alosaimi

نرحّب بأسئلتكم. راجعوا أيضًا وثيقة أسئلة وأجوبة لجنة التحكيم والوثائق الأمنية في هذه الحزمة.